ACP-Fragenkatalog

> Übersetzung der englischen Fassung (`assessment/assessment-questionnaire.md`). Bei Abweichungen gilt die englische Fassung.

Dieser Fragenkatalog unterstützt Assessoren und Organisationen bei der Durchführung eines **Active Cyber Program (ACP) Assessments** oder einer Selbstbewertung.

Jede Zeile entspricht einem Control der ACP-Checkliste (`assessment/assessment-checklist.md`, Englisch). Die Control-IDs sind in beiden Sprachen identisch. Die Leitfragen helfen, **pro Control eine Bewertung** festzulegen. Die Fragen werden nicht einzeln bewertet.

Framework-Version: **ACP 1.5.1**

Anleitung

1. Bestätigen Sie den Scope des Assessments und klären Sie, ob die Domäne KI-Sicherheit (Domäne 11) anwendbar ist.
2. Gehen Sie für jedes Control die Leitfragen mit den verantwortlichen Personen durch.
3. Halten Sie die geprüften Nachweise fest (Dokumentname, System, Screenshot, Interview).
4. Vergeben Sie pro Control eine Bewertung. Verwenden Sie N/A nur, wo das Scoring-Modell dies zulässt.
5. Berechnen Sie die Domänen-Scores und den ACP-Gesamtscore gemäss `assessment/scoring-model.md` (Englisch).

Score	Bedeutung	Beschreibung
0	Nicht umgesetzt	Das Control existiert nicht, ist nicht umgesetzt, oder es liegt kein Nachweis vor.
1	Teilweise umgesetzt	Das Control existiert, ist aber unvollständig, wird uneinheitlich angewendet oder deckt nur einen Teil des Scopes ab.
2	Umgesetzt	Das Control ist im gesamten Scope umgesetzt und dokumentiert, und Nachweise belegen, dass es wirksam betrieben wird.
3	Aktiv gesteuert	Zusätzlich wird das Control überwacht, in festgelegten Abständen überprüft und laufend verbessert.

Mit **[KO]** markierte Controls sind Knock-out-Controls. Eine Bewertung von 0 schliesst die Zertifizierung aus. Knock-out-Controls können nicht als N/A markiert werden.

Angaben zum Assessment

Organisation:

Datum des Assessments:

Assessor:

Domäne KI-Sicherheit anwendbar: □ Ja □ Nein

Domäne 1 – Unternehmens- und Sicherheits-Governance (kritisch)

Englisch: Business & Security Governance

ID	Control	Leitfragen	Score	Nachweise / Notizen
1.1	Eine Cybersecurity-Strategie ist dokumentiert	• Ist eine dokumentierte Cybersecurity- oder Informationssicherheitsstrategie vorhanden? • Wurde die Strategie von der Geschäftsleitung genehmigt? • Wann wurde die Strategie zuletzt überprüft?		
1.2	Cybersecurity-Ziele sind definiert und auf die Geschäftsziele abgestimmt	• Sind Cybersecurity-Ziele definiert und dokumentiert? • Sind die Ziele aus den Geschäftszielen abgeleitet? • Werden die Ziele regelmässig überprüft?		
1.3	Sicherheitsverantwortlichkeiten sind in der Organisation zugewiesen	• Sind Verantwortlichkeiten für Cybersecurity definiert? • Ist eine verantwortliche Person für Cybersecurity benannt (z. B. CISO, Informationssicherheitsbeauftragte)? • Sind Stellvertretungen geregelt?		
1.4	Sicherheitsthemen werden auf Ebene der Geschäftsleitung besprochen	• Werden Cybersecurity-Themen regelmässig in Sitzungen der Geschäftsleitung besprochen? • Werden Entscheidungen zur Cybersecurity dokumentiert?		
1.5	Sicherheitsinitiativen werden geplant und verfolgt	• Gibt es eine Roadmap für Sicherheitsmassnahmen? • Haben die Massnahmen Verantwortliche, Budgets und Termine? • Wird der Fortschritt verfolgt?		
1.6	Es gibt ein Sicherheitsreporting an die Geschäftsleitung	• Erhält die Geschäftsleitung regelmässig Sicherheitsberichte? • Werden die Ergebnisse von Sicherheitsassessments an die Geschäftsleitung kommuniziert?		

Domänen-Score:

Domäne 2 – Risikomanagement

Englisch: Risk Management

ID	Control	Leitfragen	Score	Nachweise / Notizen
2.1	Cybersecurity-Risiken werden formell identifiziert	• Gibt es einen Prozess zur Identifikation von Cybersecurity-Risiken? • Werden Risiken bei Änderungen an Systemen oder Prozessen neu bewertet? • Werden Cloud-Risiken berücksichtigt?		
2.2	Ein Risikoregister ist vorhanden	• Wird ein Risikoregister geführt? • Hat jedes Risiko eine verantwortliche Person?		
2.3	Risiken werden nach Auswirkung und Eintrittswahrscheinlichkeit bewertet	• Ist eine dokumentierte Methodik zur Risikobewertung vorhanden? • Werden Risiken nach Eintrittswahrscheinlichkeit und Auswirkung bewertet?		
2.4	Massnahmen zur Risikominderung sind definiert	• Sind für relevante Risiken Massnahmen zur Risikominderung definiert? • Wird die Umsetzung der Massnahmen bis zum Abschluss verfolgt? • Wird die Akzeptanz von Restrisiken formell genehmigt?		
2.5	Risiken werden periodisch überprüft	• Werden Risiken in festgelegten Abständen überprüft? • Wann fand die letzte Überprüfung statt?		
2.6	Lieferkettenrisiken werden bewertet, und mit kritischen Lieferanten sind Sicherheitsanforderungen vereinbart	• Sind kritische Lieferanten und Dienstleister identifiziert? • Werden deren Sicherheitsrisiken und -praktiken vor und während der Zusammenarbeit bewertet, einschliesslich der Entwicklungspraktiken von Softwarelieferanten? • Sind Sicherheitsanforderungen in den Verträgen mit kritischen Lieferanten enthalten?		

Domänen-Score:

Domäne 3 – Sicherheitsrichtlinien und -prozesse

Englisch: Security Policies & Processes

ID	Control	Leitfragen	Score	Nachweise / Notizen
3.1	Eine Informationssicherheitsrichtlinie ist vorhanden	• Ist eine Informationssicherheitsrichtlinie dokumentiert und zugänglich? • Wurde sie von der Geschäftsleitung genehmigt? • Wird sie regelmässig überprüft?		
3.2	Nutzungsrichtlinien sind definiert	• Ist eine Nutzungsrichtlinie (Acceptable Use Policy) vorhanden? • Sind Regeln für die Nutzung von IT-Systemen und Cloud-Diensten definiert?		
3.3	Backup-Richtlinien sind dokumentiert	• Ist eine Backup-Richtlinie vorhanden? • Legt sie Umfang, Häufigkeit, Aufbewahrungsdauer und Verantwortlichkeiten für die Wiederherstellung fest?		
3.4	Verfahren für das Patch-Management sind vorhanden	• Ist ein Patch-Management-Prozess definiert? • Legt er Fristen abhängig vom Schweregrad fest?		
3.5	Verfahren zur Reaktion auf Sicherheitsvorfälle sind definiert	• Ist ein Verfahren zur Reaktion auf Sicherheitsvorfälle dokumentiert? • Legt es Rollen, Meldewege und Meldepflichten fest?		
3.6	Sicherheitsverantwortlichkeiten sind mit den Mitarbeitenden vereinbart, und Sicherheitsverfahren werden ihnen kommuniziert	• Sind Sicherheitspflichten und Vertraulichkeit in Arbeitsverträgen oder separaten Vereinbarungen geregelt? • Werden für Rollen mit Zugang zu sensiblen Informationen Hintergrundprüfungen durchgeführt, soweit rechtlich zulässig? • Werden die Mitarbeitenden über Sicherheitsrichtlinien und -verfahren informiert, und bestätigen sie die Kenntnisnahme?		

Domänen-Score:

Domäne 4 – Identitäts- und Zugriffsmanagement (kritisch)

Englisch: Identity & Access Management

ID	Control	Leitfragen	Score	Nachweise / Notizen
4.1	Die Verwaltung von Benutzerkonten ist geregelt	• Gibt es einen definierten Prozess zum Erstellen, Ändern und Entfernen von Benutzerkonten? • Sind alle Konten personenbezogen (keine geteilten Konten)?		
4.2	Rollenbasierte Zugriffskontrolle ist umgesetzt	• Werden Zugriffsrechte anhand von Rollen vergeben? • Wird das Prinzip der minimalen Rechte angewendet?		
4.3	Für Fernzugriff, Cloud-Dienste und administrative Konten wird Multi-Faktor-Authentifizierung eingesetzt **[KO]**	• Ist MFA für Fernzugriff, Cloud-Dienste und E-Mail erzwungen? • Ist MFA für alle administrativen Konten erzwungen? • Sind Ausnahmen dokumentiert und genehmigt?		
4.4	Privilegierte Konten sind eingeschränkt und werden überwacht **[KO]**	• Sind privilegierte Konten von den Konten für die tägliche Arbeit getrennt? • Ist die Anzahl privilegierter Konten begrenzt? • Werden privilegierte Aktivitäten protokolliert und überprüft?		
4.5	Zugriffsrechte werden periodisch überprüft	• Werden Zugriffsrechte in festgelegten Abständen überprüft? • Werden die Ergebnisse dokumentiert und Korrekturen umgesetzt?		
4.6	Benutzerkonten werden beim Austritt von Mitarbeitenden entfernt	• Werden Konten beim Austritt oder Rollenwechsel zeitnah deaktiviert? • Ist der Prozess mit der Personalabteilung verknüpft?		

Domänen-Score:

Domäne 5 – Infrastruktursicherheit

Englisch: Infrastructure Security

ID	Control	Leitfragen	Score	Nachweise / Notizen
5.1	Ein Inventar der Systeme und Server ist vorhanden	• Wird ein Inventar der Server, Systeme und Cloud-Ressourcen geführt? • Ist es aktuell, und hat jedes System eine verantwortliche Person?		
5.2	Standards für sichere Konfiguration sind definiert	• Sind Standards für sichere Konfigurationen (Härtungsvorgaben) definiert? • Basieren sie auf anerkannten Benchmarks (z. B. CIS Benchmarks)? • Wird die Einhaltung der Standards überprüft?		
5.3	Systeme werden regelmässig gepatcht und aktualisiert **[KO]**	• Werden Sicherheitsupdates innerhalb festgelegter Fristen eingespielt? • Werden kritische Schwachstellen priorisiert behoben? • Werden nicht mehr unterstützte Systeme identifiziert und behandelt?		
5.4	Der administrative Zugriff auf Systeme ist eingeschränkt	• Ist der administrative Zugriff auf berechtigte Personen und dedizierte Zugriffswege beschränkt? • Sind Administrationsschnittstellen vor direktem Zugriff aus dem Internet geschützt?		
5.5	Änderungen an Systemen und Software werden dokumentiert und genehmigt; wird Software entwickelt oder in Auftrag gegeben, folgt dies sicheren Entwicklungspraktiken	• Werden Änderungen an Systemen und Software dokumentiert und genehmigt? • Ist ein Change-Management-Prozess vorhanden? • Falls Software selbst entwickelt oder in Auftrag gegeben wird: Sind sichere Entwicklungspraktiken festgelegt (z. B. sicheres Programmieren, Sicherheitstests, Trennung von Entwicklung und Produktion)?		
5.6	Die Cloud-Infrastruktur folgt Vorgaben für sichere Konfiguration	• Sind Cloud-Umgebungen nach bewährten Sicherheitspraktiken konfiguriert? • Wird die Sicherheitslage der Cloud überwacht (z. B. Secure Score, Posture Management)?		

Domänen-Score:

Domäne 6 – Endgerätesicherheit

Englisch: Endpoint Security

ID	Control	Leitfragen	Score	Nachweise / Notizen
6.1	Software für den Endgeräteschutz ist installiert	• Ist auf allen Endgeräten ein Endgeräteschutz (Antivirus oder EDR) installiert? • Wird dessen Status zentral überwacht?		
6.2	Geräte werden zentral verwaltet	• Werden die Geräte zentral verwaltet (z. B. MDM/UEM)? • Werden Compliance-Richtlinien durchgesetzt?		
6.3	Festplattenverschlüsselung ist auf Endgeräten aktiviert	• Ist die Festplattenverschlüsselung auf allen Laptops und Desktops aktiviert? • Werden die Wiederherstellungsschlüssel sicher aufbewahrt?		
6.4	Updates für Endgeräte werden automatisch verteilt	• Werden Updates für Betriebssysteme und Anwendungen automatisch verteilt? • Wird der Update-Stand überwacht?		
6.5	Mobile Geräte werden sicher verwaltet	• Werden mobile Geräte verwaltet? • Sind Unternehmensdaten auf privaten Geräten geschützt?		
6.6	Verlorene oder gestohlene Geräte können aus der Ferne gesteuert oder gelöscht werden	• Können verlorene oder gestohlene Geräte aus der Ferne gesperrt oder gelöscht werden? • Gibt es einen Prozess zur Meldung verlorener Geräte?		

Domänen-Score:

Domäne 7 – Netzwerksicherheit

Englisch: Network Security

ID	Control	Leitfragen	Score	Nachweise / Notizen
7.1	Netzwerk-Firewalls sind im Einsatz	• Sind an den Netzwerkgrenzen Firewalls im Einsatz? • Werden die Firewall-Regeln regelmässig überprüft?		
7.2	Netzwerksegmentierung wird eingesetzt, wo sinnvoll	• Sind die Netzwerke segmentiert (z. B. Server, Clients, Gäste)? • Sind kritische Systeme isoliert?		
7.3	Sicherer Fernzugriff (z. B. VPN oder Zero Trust Network Access) ist umgesetzt	• Erfolgt der Fernzugriff über sichere Lösungen (VPN oder ZTNA)? • Ist der Fernzugriff auf berechtigte Benutzer und Geräte beschränkt?		
7.4	Der Netzwerkverkehr wird überwacht	• Wird der Netzwerkverkehr auf verdächtige Aktivitäten überwacht? • Werden Systeme zur Erkennung oder Verhinderung von Angriffen (IDS/IPS) eingesetzt?		
7.5	Drahtlosnetzwerke sind sicher konfiguriert	• Sind WLANs mit aktueller Verschlüsselung gesichert (z. B. WPA2/WPA3 Enterprise)? • Ist das Gäste-WLAN von den internen Netzwerken getrennt?		
7.6	Der Netzwerkzugang ist auf berechtigte Geräte beschränkt	• Ist der Netzwerkzugang auf berechtigte Geräte beschränkt (z. B. NAC, 802.1X)? • Werden unbekannte Geräte erkannt?		

Domänen-Score:

Domäne 8 – Datensicherheit, Backup und Wiederherstellung (kritisch)

Englisch: Data Protection, Backup & Recovery

ID	Control	Leitfragen	Score	Nachweise / Notizen
8.1	Sensible Daten sind identifiziert und klassifiziert	• Sind sensible Daten identifiziert? • Ist ein Klassifizierungsschema für Daten vorhanden, und wird es angewendet?		
8.2	Sensible Daten werden auf Basis einer festgelegten Kryptografie-Richtlinie verschlüsselt	• Ist eine Kryptografie-Richtlinie festgelegt (z. B. zugelassene Algorithmen, Schlüssellängen, Schlüsselverwaltung)? • Werden sensible Daten gemäss dieser Richtlinie bei der Speicherung und Übertragung verschlüsselt? • Werden die Schlüssel sicher verwaltet?		
8.3	Sichere Verfahren zur Dateiübertragung werden eingesetzt	• Werden sichere Verfahren zur Dateiübertragung eingesetzt (z. B. SFTP, sichere Austauschplattformen)? • Sind unsichere Übertragungsverfahren untersagt?		
8.4	Backup-Verfahren sind umgesetzt und getestet **[KO]**	• Werden Backups gemäss der Backup-Richtlinie durchgeführt? • Werden Wiederherstellungen regelmässig getestet und dokumentiert?		
8.5	Backup-Daten sind vor unberechtigtem Zugriff und Manipulation geschützt **[KO]**	• Sind Backups gegen unberechtigten Zugriff und Ransomware geschützt (z. B. Offline- oder unveränderbare Kopien, separate Zugangsdaten)? • Wird mindestens eine Backup-Kopie an einem separaten Standort aufbewahrt?		
8.6	Dateien, die ausserhalb geschützter Systeme ausgetauscht oder archiviert werden, sind mit aktuellen Algorithmen verschlüsselt (z. B. AES-256)	• Werden Dateien, die ausserhalb geschützter Systeme ausgetauscht oder archiviert werden, verschlüsselt? • Werden aktuelle Algorithmen verwendet (z. B. AES-256)?		
8.7	Notfall- und Wiederherstellungspläne (Business Continuity und Disaster Recovery) sind dokumentiert und getestet	• Sind kritische Geschäftsprozesse und IT-Systeme identifiziert, mit festgelegten Zielen für Wiederanlaufzeit und maximalen Datenverlust (RTO/RPO)? • Sind für diese Prozesse und Systeme Notfall- und Wiederherstellungspläne dokumentiert? • Werden die Pläne regelmässig getestet (z. B. Wiederherstellungstests, Planspiele), und werden die Ergebnisse dokumentiert?		
8.8	Krisenmanagement und Notfallkommunikation sind festgelegt	• Ist ein Krisenstab mit Rollen und Entscheidungsbefugnissen festgelegt? • Sind Kommunikationswege für den Notfall festgelegt, die auch bei Ausfall der primären IT-Systeme funktionieren? • Sind die Kontaktlisten für interne und externe Stellen (z. B. Behörden, Versicherungen, wichtige Lieferanten) aktuell?		

Domänen-Score:

Domäne 9 – Monitoring und Vorfallbehandlung (kritisch)

Englisch: Monitoring & Incident Response

ID	Control	Leitfragen	Score	Nachweise / Notizen
9.1	Sicherheitsprotokolle werden gesammelt	• Werden Sicherheitsprotokolle (Logs) der relevanten Systeme gesammelt? • Werden die Logs zentral gespeichert und für eine festgelegte Dauer aufbewahrt?		
9.2	Die Logs werden überwacht	• Werden die Logs überwacht? • Ist die Überwachung automatisiert (z. B. SIEM)?		
9.3	Sicherheitsalarme werden regelmässig geprüft	• Werden Sicherheitsalarme regelmässig geprüft? • Sind Verantwortlichkeiten und Reaktionszeiten festgelegt?		
9.4	Verfahren zur Reaktion auf Sicherheitsvorfälle sind dokumentiert und einsatzbereit **[KO]**	• Ist ein Verfahren zur Reaktion auf Sicherheitsvorfälle dokumentiert und den verantwortlichen Personen bekannt? • Wurde es getestet (z. B. mit einem Planspiel)?		
9.5	Sicherheitsvorfälle werden erfasst und untersucht	• Werden Sicherheitsvorfälle erfasst und untersucht? • Werden Ursachen analysiert und Erkenntnisse (Lessons Learned) dokumentiert?		
9.6	Eskalations- und Meldewege, einschliesslich gesetzlicher Meldepflichten, sind festgelegt	• Sind Eskalationswege festgelegt, einschliesslich Geschäftsleitung und externer Stellen? • Sind die anwendbaren gesetzlichen Meldepflichten und Fristen bekannt (z. B. NIS2: Frühwarnung innerhalb von 24 Stunden, Meldung innerhalb von 72 Stunden, Abschlussbericht innerhalb eines Monats)? • Ist festgelegt, wer an Behörden meldet und wie?		

Domänen-Score:

Domäne 10 – Kontinuierliche Verbesserung

Englisch: Continuous Improvement

ID	Control	Leitfragen	Score	Nachweise / Notizen
10.1	Sicherheitsüberprüfungen werden periodisch durchgeführt	• Werden Sicherheitsüberprüfungen in festgelegten Abständen durchgeführt? • Werden die Ergebnisse dokumentiert?		
10.2	Sicherheitsaudits oder -assessments werden durchgeführt	• Werden interne oder externe Sicherheitsaudits durchgeführt? • Werden die Feststellungen verfolgt?		
10.3	Schwachstellen werden durch regelmässige Prüfungen identifiziert, und gemeldete Schwachstellen werden behandelt	• Werden regelmässig Schwachstellenscans oder Penetrationstests durchgeführt? • Werden die Feststellungen behoben? • Gibt es einen Prozess für die Entgegennahme und Behandlung von Schwachstellenmeldungen Dritter (z. B. Sicherheitskontakt, Richtlinie zur Offenlegung von Schwachstellen)?		
10.4	Verbesserungsmassnahmen werden verfolgt	• Werden Verbesserungsmassnahmen mit Verantwortlichen und Terminen verfolgt? • Wird über den Fortschritt berichtet?		
10.5	Mitarbeitende und Geschäftsleitung erhalten Schulungen zur Sicherheitssensibilisierung	• Erhalten alle Mitarbeitenden Schulungen zur Sicherheitssensibilisierung? • Erhalten die Mitglieder der Geschäftsleitung Cybersecurity-Schulungen (z. B. gemäss NIS2 Art. 20 Abs. 2)? • Werden Phishing-Simulationen durchgeführt, und wird die Teilnahme erfasst?		
10.6	Sicherheitskennzahlen oder KPIs werden ausgewertet	• Sind Sicherheitskennzahlen oder KPIs definiert? • Werden sie ausgewertet und berichtet?		

Domänen-Score:

Domäne 11 – KI-Sicherheit (falls anwendbar; wenn anwendbar kritisch)

Englisch: AI Security

ID	Control	Leitfragen	Score	Nachweise / Notizen
11.1	KI-Systeme sind identifiziert und inventarisiert, mit festgelegten Verantwortlichen	• Sind die eingesetzten KI-Systeme und KI-Dienste identifiziert und inventarisiert? • Hat jedes KI-System eine verantwortliche Person?		
11.2	KI-Sicherheitsrisiken werden bewertet	• Werden KI-spezifische Risiken bewertet (z. B. Datenabfluss, Prompt Injection, Modellmanipulation)? • Werden regulatorische Anforderungen (z. B. EU AI Act) berücksichtigt?		
11.3	Richtlinien zur KI-Nutzung und Sicherheitsmassnahmen sind festgelegt und umgesetzt	• Sind Richtlinien zur KI-Nutzung festgelegt und kommuniziert? • Sind technische Schutzmassnahmen (Guardrails) und Zugriffskontrollen für KI-Systeme umgesetzt?		
11.4	KI-Systeme werden auf Sicherheitsereignisse und unerwartetes Verhalten überwacht	• Werden KI-Systeme auf Sicherheitsereignisse überwacht? • Wird unerwartetes Verhalten erkannt und geprüft?		
11.5	KI-Sicherheitsvorfälle werden untersucht	• Werden KI-bezogene Sicherheitsvorfälle erfasst und untersucht?		
11.6	KI-Sicherheit ist Teil des Reportings an die Geschäftsleitung und der kontinuierlichen Verbesserung	• Ist KI-Sicherheit Teil des Reportings an die Geschäftsleitung? • Ist KI-Sicherheit Teil der Aktivitäten zur kontinuierlichen Verbesserung?		

Domänen-Score:

Ergebnisübersicht

Domäne	Kritisch	Score
1. Unternehmens- und Sicherheits-Governance	Ja	
2. Risikomanagement		
3. Sicherheitsrichtlinien und -prozesse		
4. Identitäts- und Zugriffsmanagement	Ja	
5. Infrastruktursicherheit		
6. Endgerätesicherheit		
7. Netzwerksicherheit		
8. Datensicherheit, Backup und Wiederherstellung	Ja	
9. Monitoring und Vorfallbehandlung	Ja	
10. Kontinuierliche Verbesserung		
11. KI-Sicherheit (falls anwendbar)	Ja	

ACP-Gesamtscore:

ACP-Reifegrad:

Knock-out-Control mit Score 0: □ Nein □ Ja (ID:)